

GUIDE D'AUDIT FINAL & PLAN DE TEST API

Application de Gestion des Interventions - Module API Mobile Technicien (28 Routes)
Généré le 12/08/2026 à 22:04

1. SCÉNARIO DE TEST WORKFLOW BOUT EN BOUT (END-TO-END)

Exécutez les requêtes suivantes dans l'ordre exact pour valider le cycle de vie complet d'une intervention :

#	Méthode	Route API	Action & Résultat attendu
1	POST	/api/login	Authentification technicien. Récupérer le token Bearer.
2	GET	/api/interventions	Lister les interventions assignées. Choisir une intervention <i>Planifiée</i> .
3	POST	/api/interventions/{id}/accept	Accepter l'intervention. Statut passe à Acceptée .
4	POST	/api/interventions/{id}/start	Démarrer l'intervention (mode GPS/QR/NFC/Manuel). Statut passe à En cours .
5	POST	/api/interventions/{id}/tracking/start	Initialiser la session de tracking GPS de la présence.
6	POST	/tracking/sessions/{session}/points	Envoyer les coordonnées GPS (latitude, longitude).
7	POST	/tracking/sessions/{session}/stop	Fermer la session de tracking.
8	GET	/api/interventions/{id}/formulaire	Charger le formulaire dynamique associé au type d'intervention.
9	POST	/api/interventions/{id}/formulaire	Envoyer les réponses au formulaire. Statut passe à Formulaire rempli .
10	POST	/api/interventions/{id}/rapport	Rédiger et sauvegarder le rapport d'intervention.
11	POST	/api/interventions/{id}/validate	Valider et clôturer l'intervention. Statut passe à Terminée .
12	GET	/api/rapports/{id}/pdf	Télécharger le document PDF du rapport d'intervention généré.
13	GET	/api/notifications	Vérifier la réception des notifications générées pour le technicien.

2. CHECKLIST DE VÉRIFICATION PAR MODULE (28 ENDPOINTS)

A. Module Authentification & Profil

Check	Méthode	Route API	Description de la vérification
[]	POST	/api/login	Connexion utilisateur. Retourne token + infos user.
[]	GET	/api/me	Profil utilisateur authentifié et ses rôles.
[]	POST	/api/logout	Révoque le token Sanctum actuel.
[]	GET	/api/profile	Profil complet technicien avec statistiques d'intervention.
[]	PUT	/api/profile	Mise à jour infos (nom, prénom, email, téléphone, adresse).
[]	POST	/api/profile/photo	Upload avatar (form-data image, max 5Mo).
[]	PUT	/api/profile/password	Changement de mot de passe avec validation mot de passe actuel.

B. Module Interventions & Formulaires

Check	Méthode	Route API	Description de la vérification
[]	GET	/api/interventions	Liste des interventions filtrées par technicien.
[]	GET	/api/interventions/{id}	Détails complets de l'intervention avec relations.
[]	POST	/api/interventions/{id}/accept	Accepter l'intervention planifiée.
[]	POST	/api/interventions/{id}/start	Démarrer l'intervention (mode GPS/QR/NFC/Manuel).
[]	POST	/api/interventions/{id}/validate	Valider et clôturer l'intervention (Admin/Tech autorisé).
[]	GET	/api/interventions/{id}/formulaire	Récupérer les questions du formulaire dynamique.
[]	POST	/api/interventions/{id}/formulaire	Soumission réservée exclusivement au Technicien.

C. Module Tracking GPS, Rapports & Notifications

Check	Méthode	Route API	Description de la vérification
[]	POST	/api/interventions/{id}/tracking/start	Démarrage session de tracking.
[]	POST	/tracking/sessions/{session}/points	Ajout d'un point GPS de positionnement.
[]	POST	/tracking/sessions/{session}/stop	Arrêt de la session de tracking.
[]	GET	/api/interventions/{id}/tracking	Consultation des sessions de tracking de l'intervention.
[]	GET	/api/rapports	Liste paginée des rapports d'intervention.
[]	GET	/api/rapports/{rapport}	Détails d'un rapport par son ID.
[]	GET	/api/interventions/{id}/rapport	Rapport associé à une intervention spécifique.
[]	POST	/api/interventions/{id}/rapport	Créer ou mettre à jour le rapport d'intervention.
[]	GET	/api/rapports/{rapport}/pdf	Téléchargement du rapport au format PDF.
[]	DELETE	/api/rapports/{rapport}	Suppression d'un rapport (Admin).
[]	GET	/api/notifications	Toutes les notifications technicien avec `unread_count`.
[]	GET	/api/notifications/unread	Notifications non lues uniquement.
[]	POST	/api/notifications/{id}/read	Marquer une notification comme lue.
[]	POST	/api/notifications/read-all	Marquer toutes les notifications comme lues.

3. AUDIT DE SÉCURITÉ, RBAC ET ERREURS ATTENDUES

- **Accès sans Token (401 Unauthorized)** : Envoyer une requête sans header `Authorization: Bearer <token>`. La réponse doit être 401.
- **Isolation inter-techniciens (403 Forbidden)** : Tenter d'accéder ou de modifier une intervention d'un autre technicien avec le compte Technicien A. La réponse doit être 403.
- **Restrictions Rôles Formulaires** : Tenter d'uploader un formulaire avec un compte Admin ou Client. Seul le Technicien doit être autorisé.

- **Validation des Données (422 Unprocessable Entity)** : Envoyer des données erronées (ex: email invalide au login, photo non image). Vérifier le retour 422 avec détails `errors` .